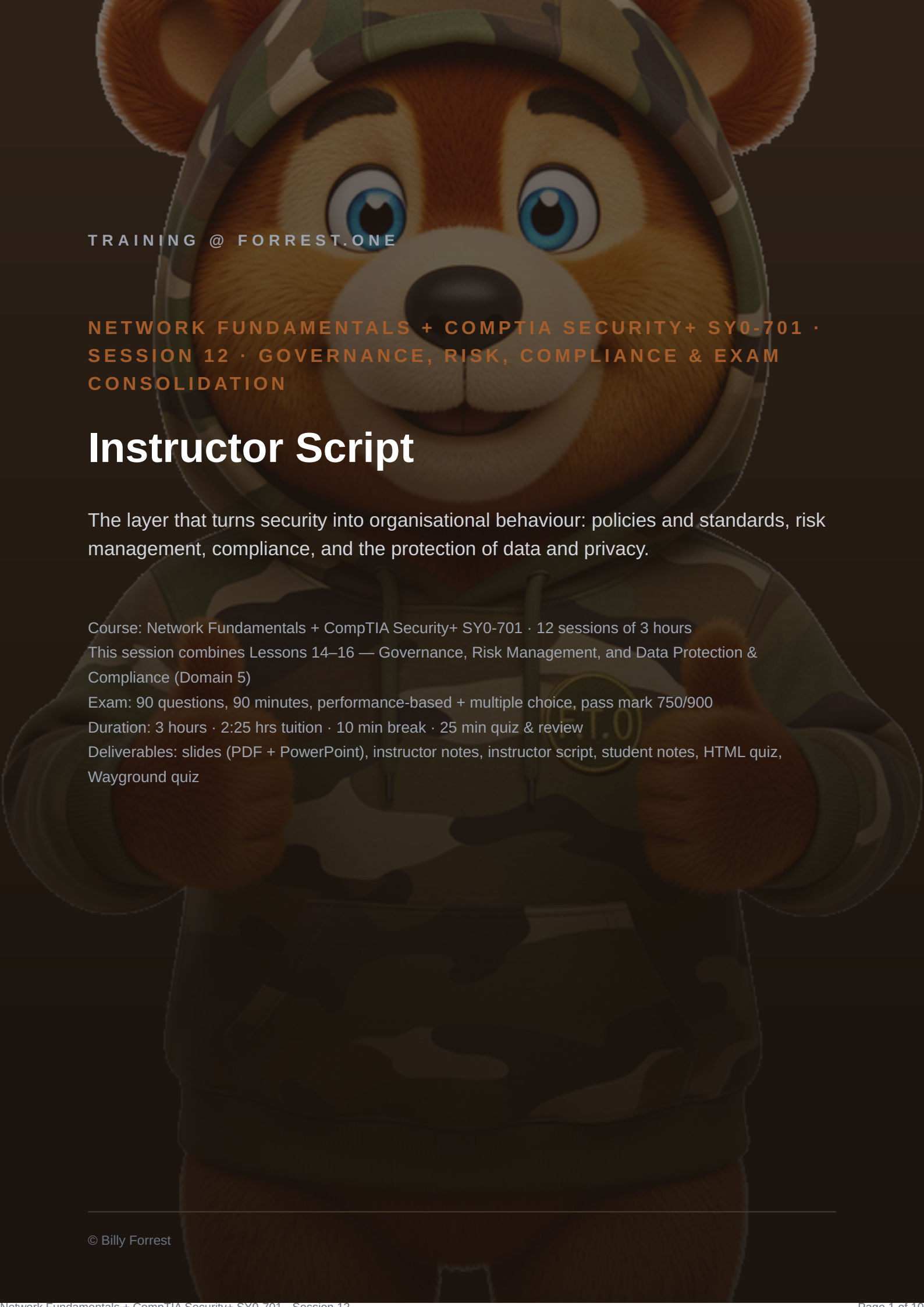




TRAINING @ FORREST.ONE

**NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 12 · GOVERNANCE, RISK, COMPLIANCE & EXAM
CONSOLIDATION**

Instructor Script

The layer that turns security into organisational behaviour: policies and standards, risk management, compliance, and the protection of data and privacy.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session combines Lessons 14–16 — Governance, Risk Management, and Data Protection & Compliance (Domain 5)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Script: Governance, Risk, Compliance & Exam Consolidation

A word-for-word delivery script for Session 12, the course finale. Stage directions appear in square brackets. Each slide runs roughly 45–90 seconds of speech; activities and discussions expand the timings in the instructor notes.

Slide 1 · Title

Welcome to Session 12, the final session of the course: Governance, Risk, Compliance and Exam Consolidation. Eleven sessions built the technical estate. Today we step back from those technical controls and examine how security is governed. Governance sets direction, rules and accountability. We will then run risk management end to end, manage vendors and compliance, and design an awareness programme. This is where security becomes an organisational discipline rather than a set of tools. Keep asking one question throughout: what has the business decided, and why? That question will keep you useful long after the examination.

Slide 2 · The capstone

A quick orientation. This session is Domain 5, Security Program Management and Oversight, twenty percent of the paper. The thread through today: governance sets direction, risk management directs money, compliance proves the work, and awareness makes people part of the defence. It is a vocabulary-precise domain, so get the definitions exact and the scenario questions answer themselves.

Slide 3 · Why governance comes first

Governance is the backbone of a security programme. It aligns security activity with business objectives, so security is never implemented in isolation. A breach is expensive, and so is security that protects nothing that matters. Governance directs investment at the assets and services the business truly depends on. It also sets the risk appetite that everything else must respect. A bank prioritises data protection and regulatory compliance, because that is what its business rests on. That is how security earns its budget.

Slide 4 · Structures, authority and accountability

Governance only works when it has structure. A security committee is cross functional, drawing in information technology, legal, human resources and operations, so policy is developed and reviewed from every angle rather than from one department view. Reporting lines matter, which is why the chief information security officer reports to the chief executive or the board. Executive oversight supplies direction, resources and

regular review. Then authority and accountability, which the exam separates carefully. Authority is the documented power to decide, approve or authorise. Accountability is answering for the outcome, and audits reinforce it.

Slide 5 · Executive roles and oversight

At the executive level, the chief information security officer shapes strategy, develops policy, ensures compliance and manages risk. The role also translates technical problems into language executives can act on. Security directors report to that officer, own particular domains, and contribute to incident response and recovery planning. Above them, the board of directors must ensure a strategy exists and is genuinely implemented. The board reviews policy, tests risk management practice and keeps the organisation accountable. That is what oversight looks like in practice.

Slide 6 · Operational roles and data ownership

The security analyst is on the front line, monitoring for threats, analysing security data and investigating incidents. The security administrator maintains the infrastructure, configuring firewalls, intrusion detection systems and antivirus, and running regular audits. The security architect designs the framework so that security fits the wider infrastructure and scales with it. Then data ownership. The data owner classifies the data and decides who may access it and how it is protected. The data custodian implements the controls: encryption, access control and backups. Clear roles prevent both gaps and duplication.

Slide 7 · The four governance document types

These four documents form a hierarchy, and the exam expects you to separate them. A policy is a high level statement of management intent, broad and strategic. A standard turns that intent into a mandatory, measurable requirement, such as passwords of at least twelve characters mixing letters, numbers and symbols. A guideline is recommended practice, useful for configuration decisions, and it is not mandatory. A procedure gives the exact steps for a task. Every document moves through a lifecycle: developed with stakeholders, approved by the right authority, distributed, and reviewed so it stays current.

Slide 8 · Discussion

[Run the discussion per the instructor notes.] A password standard says twelve characters minimum; a guideline suggests passphrases. What is the difference in force? [Take answers.] The standard is mandatory, and audits measure against it. The guideline is recommended, and departures are acceptable if justified. Standards are measured; guidelines are advisory.

Slide 9 · Regulatory requirements

Security does not happen in a vacuum. Requirements arrive from regulators, from contracts and from the law itself. Regulatory requirements are mandatory, and they usually target a sector or a region. In American healthcare, the Health Insurance Portability and Accountability Act requires administrative, physical and

technical safeguards for electronic protected health information. Card processing falls under the Payment Card Industry Data Security Standard, which demands strong access control and regular testing. Energy providers answer to the North American Electric Reliability Corporation critical infrastructure standards. The General Data Protection Regulation covers personal data of people in the European Union, wherever the organisation sits. And California adds the CCPA. External obligations become internal policy, and internal policy becomes the controls you deploy.

Slide 10 · Contractual obligations

Contracts carry obligations too, and those are enforceable. A service level agreement can specify the controls a provider must implement, including encryption standards, incident response times and regular audits. A data processing agreement sets out the duties of a processor and a controller when personal data is involved, and usually requires breach notification and audit rights. Partnership agreements may require both sides to follow the National Institute of Standards and Technology Cybersecurity Framework. Your customers can therefore impose security requirements on you, and failing them is a breach of contract.

Slide 11 · Legal considerations

Legal considerations shape governance in three ways. First, liability: after a breach an organisation may face legal action from affected parties and financial penalties from regulators. Demonstrating due diligence reduces that exposure, because it shows the reasonable steps you took. Second, jurisdiction, because a multinational answers to the requirements of every place it does business. Third, privacy law, which increasingly demands privacy by design, a data protection impact assessment, and often a data protection officer. Those external requirements then flow into internal policy, which is assessed, updated and audited.

Slide 12 · How you find risks

Risk management begins with identification. Start with an asset inventory covering physical, digital and human resources, because you cannot protect what you have not listed. Key servers, databases and personnel each carry their own vulnerabilities. Next, threat modelling. This is a structured way of asking how a system could be attacked and what the impact would be. A threat model for a web application, for example, names injection attacks and maps how they occur. Finally, vulnerability assessment uses scanning tools to find known weaknesses, such as outdated software. You cannot manage a risk you have never named.

Slide 13 · Likelihood, impact and two methods

Once risks are named, you assess them on two axes. Likelihood is the probability of the event, judged from the threat landscape and from past incidents. Impact is the consequence: financial loss, reputational damage and operational disruption. A data breach brings penalties and lost trust. Then two ways to express the result. Qualitative assessment uses ratings such as high, medium and low, and it is quick, which makes it ideal for triage. Quantitative assessment uses numbers and money, and it is precise but data hungry. Most organisations use both.

Slide 14 · The calculation, step by step

Here is the arithmetic, with real figures. Asset value is what the asset is worth to the business: one hundred thousand. The exposure factor is the share lost if the risk occurs, here forty percent. Single loss expectancy is asset value times exposure factor, so forty thousand. The annual rate of occurrence is the frequency expected each year, and zero point one means once in ten years. Annualised loss expectancy multiplies the single loss expectancy by that rate, so four thousand a year. Now weigh the cost of a control against the loss it prevents.

Slide 15 · The register is a living document

Every identified risk goes into a risk register. The register describes the risk and the circumstances under which it might occur. It records a rating built from likelihood and impact, which tells you what needs attention first. It names a risk owner, one person or team accountable for managing that risk. And it tracks treatment status, whether that risk is being monitored, mitigated, transferred or accepted. The register is a living document, so new risks are added, ratings are reassessed, and stakeholders across the business are engaged.

Slide 16 · Appetite and tolerance are not the same

Two related ideas that the exam distinguishes. Risk appetite is the amount of risk an organisation will pursue or retain to meet its objectives. A regulated bank has a low appetite, while a young technology company accepts far more to grow. Risk tolerance is the acceptable variation from that appetite. Suppose a company accepts a five percent market share loss while chasing long term growth, but tolerates only a two percent deviation in one quarter. Appetite sets the boundary, and tolerance says how far you may drift inside it.

Slide 17 · The four responses

Four strategies, and each fits a different situation. Avoidance eliminates the risk by not doing the thing that creates it, which is effective but closes off the opportunity. Transference shifts the burden to someone else, through insurance or outsourcing, and suits risks you lack the skill to manage. Mitigation reduces likelihood or impact with controls, such as firewalls, detection systems and training. Acceptance retains the risk knowingly, when the cost of the control exceeds the impact. Match the strategy to the organisation, and revisit it as circumstances change. And remember: acceptance is a documented management decision, never an accident.

Slide 18 · Activity: respond to the risks

[Run the activity per the instructor notes. 8 minutes in pairs, 4 minutes debrief.] A legacy system that cannot be patched: mitigate with compensating controls, or accept with documented sign-off. Flood risk at the data centre: transfer, via insurance. The board accepts a risk: the decision must be recorded, with the owner and the reasoning. A supplier holding sensitive data: the contract must carry data handling, incident notification,

audit rights and an exit plan. Which response do organisations use most? Mitigate, because controls are the everyday work.

Slide 19 · Break

Ten minutes. When we return: risk reporting and business impact, then vendors, compliance, audit, and the awareness programme.

Slide 20 · The same risk, three audiences

Risk reporting fails when everybody receives the same document. Technical teams need detail: specific vulnerabilities, threat vectors, severity scores and patching plans. Executives need the business consequences, the effect on operations, finances and strategy, and they read charts rather than logs. The board and regulators want compliance, governance and plain language. The format follows the audience, whether that is a live dashboard, a detailed report or a short executive summary. Useful metrics include how often the risk occurs, how severe the impact is, and how far mitigation has progressed. Report on a regular cycle, and tailor the language to the reader.

Slide 21 · Business impact analysis

A business impact analysis is how you decide what really matters. It identifies the processes that are critical to operations, the ones whose failure would hurt most. It then maps dependencies, which systems, applications and people those processes rely on. It assesses the consequences of disruption, whether financial, reputational or regulatory. The findings drive recovery priorities, so the most critical functions are restored first. They also drive resource allocation, putting people, technology and budget where the impact would be greatest. That is how continuity planning earns its funding.

Slide 22 · Vendor assessment before contract

Third party risk starts well before the contract. You ask a new vendor to complete a security questionnaire covering encryption, network security and incident response. You review their documentation, meaning policies, procedures and any compliance reports. Where the relationship is significant, you conduct an on site assessment, because it can expose a gap between documented practice and reality. Due diligence goes wider than security: financial stability, certifications, incident history and references from other clients. Crucially, assessment depth should match the risk, so a vendor touching sensitive data gets real scrutiny. ISO 27001 and SOC 2 certifications are the common markers of maturity.

Slide 23 · Contracts that carry security

Contracts are where vendor risk is actually controlled. Specify how data is handled, stored and transmitted, including encryption standards and access controls. Define what counts as a security incident and how quickly the vendor must tell you, for example within one day of discovery. Reserve the right to audit, and state the scope and the frequency. Service level agreements should carry security metrics, such as minimum

uptime, response times for critical vulnerabilities, and compliance with a named standard. Then agree the exit, with data returned and remaining copies securely destroyed.

Slide 24 · Monitoring and rules of engagement

Contracts then need watching, because risk changes after signature. Periodic reassessment checks that the vendor still meets your requirements. Compliance verification confirms they follow the rules that apply, whether that is data protection law or healthcare regulation. Performance tracking uses agreed indicators to measure quality, timeliness and reliability. Rules of engagement set the boundaries of access, and that access follows least privilege, enforced with role based access control and multifactor authentication. Escalation procedures tell the vendor how to raise a problem, and a vendor breach still needs your incident plan.

Slide 25 · Frameworks and what applies to you

Compliance means adhering to the laws and standards that apply to you, and it is the proof that you did what the rules required. Each framework has its own territory. The Payment Card Industry Data Security Standard governs cardholder data and demands a secure network, access control and regular testing. The Health Insurance Portability and Accountability Act protects medical information. Sarbanes Oxley protects investors by requiring accurate financial reporting and internal controls. The General Data Protection Regulation covers personal data of people in the European Union. Decide what applies by industry, geography and data type, and remember that compliance is a baseline, not a finish line.

Slide 26 · Monitoring and demonstrating compliance

Compliance is continuous, not a once a year exercise. Automated tools watch for violations as they happen. A security information and event management system collects and analyses security data, alerting on policy breaches, while configuration management keeps systems on approved settings and reverses drift. Manual review still matters, because interpretation of a regulation cannot be automated. Then there is evidence: the logs, audit trails and documentation that show controls working, and audit trails must resist tampering and unauthorised access. Reporting goes to regulators, auditors and management, through dashboards and metrics.

Slide 27 · When compliance fails, and privacy duties

Non compliance is expensive in several currencies. The first is money. Under the data protection regulation, penalties can reach four percent of annual global turnover, or twenty million euro, whichever is greater. The second is permission: regulators can impose sanctions or restrict processing, and in heavily regulated sectors they can remove your authority to operate. The third is trust, because customers leave when confidence goes. The fourth is legal liability, including lawsuits and closer regulatory scrutiny. Privacy law then adds duties, including subject rights, informed consent and impact assessments, which find risk before processing begins.

Slide 28 · Internal and external audits

Audits examine controls independently and check that reality matches the paperwork. An internal audit is performed by your own staff, and its purpose is self assessment, to find weaknesses, improve process and be ready for outside scrutiny. An external audit is performed by an independent third party, often because regulation demands it, giving customers assurance. Both follow the same four stages. You plan the audit, defining scope and objectives, then gather evidence through documents, interviews and testing controls. You report findings, then track remediation until each issue is closed.

Slide 29 · Attestation and penetration testing

There are two forms of assurance. Attestation is a formal declaration that controls meet stated criteria, and the common example is a Service Organization Control report. SOC 1 covers controls relevant to financial reporting. SOC 2 covers security, availability, processing integrity, confidentiality and privacy, which is what cloud providers are asked for. SOC 3 gives the same picture at a high level. Penetration testing goes further, attacking the system with permission, in black box, white box or grey box form. Scope and rules of engagement come first, then findings are prioritised, remediated and retested.

Slide 30 · Designing an awareness programme

Awareness is programme design, not a single slide deck. Start with audience analysis, asking which roles touch sensitive data, what they already know, and where the gaps are. Then set objectives that are specific, measurable and time bound, such as being able to identify and report a phishing email. Content should be current and recognisable, built from real incidents and interactive scenarios. Delivery can be computer based for scale, instructor led for depth, or a campaign of reminders. Tailor by role, and measure with assessments, simulations and reported incidents.

Slide 31 · Phishing training and simulations

Phishing is the attack most likely to reach your users, so train for it directly. Teach recognition first: a suspicious sender, manufactured urgency, an unexpected attachment, a link to an unfamiliar site. Then teach reporting, with one obvious route, such as forwarding the message to the security team. Simulated campaigns test whether that training held, because you send them without warning and measure click rates and reporting rates. Progressive difficulty keeps people challenged, and immediate feedback explains what they missed. Watch the trends, and keep the pace reasonable, because too many simulations cause fatigue.

Slide 32 · Guidance, reporting and anomalies

Guidance only works if it is practical, so translate policy into behaviour. A password standard becomes advice about length, and a password manager that makes compliance easy. Reinforce the habits with short reminders, and deliver just in time training when a new campaign appears. Make reporting effortless, through a mailbox, a phone line or an anonymous portal. Then the cultural rule: thank the person who reports,

because punishment destroys your early warning. And watch for behaviour that does not fit, from impersonation and urgency to unescorted strangers and unattended devices.

Slide 33 · Measuring the programme and improving it

How do you know the programme works? Measure it three ways. Assessments test whether people can recognise a threat. Simulations show how they behave under a realistic attack. Incident metrics show what users are reporting, and how quickly they report it. Then improve continuously. Analyse those results for trends and gaps, refresh the content with recent incidents and current threat intelligence, and ask the audience what is not working. Vary the channels so the message stays visible, because awareness fades fast.

Slide 34 · Data classification and data states

Data needs a label. Public: no restriction, such as brochures and press releases. Internal: internal use only, such as procedures and plans. Confidential: restricted, such as HR records and contracts. Restricted: the most sensitive, such as trade secrets and health data. Classification drives the controls, so the higher the class, the stronger the protection. And data exists in three states, at rest, in transit and in use, and each state needs its own controls.

Slide 35 · Data roles and the data lifecycle

The data owner is accountable for classification, access and protection. The data steward ensures quality and governance day to day. The data custodian implements the technical controls: encryption, access control and backups. Accountable, governed, implemented: three different jobs, and the exam expects you never to swap the owner and the custodian. Data also has a lifecycle: collect, store, use, share, archive and destroy. Retention policy answers how long data is kept, and why, driven by legal and business needs. At the end of retention, destroy it securely, by wiping or physical destruction of the media.

Slide 36 · Privacy law and data sovereignty

The law above the policy. GDPR and UK GDPR are the EU and UK data protection frameworks. The principles: lawful, transparent, minimised, accurate and secure. The rights: access, rectification, erasure, portability and restriction, with consent that is informed, specific and freely given. And the breach duty: notify the regulator within seventy two hours where required. Then sovereignty. Data is subject to the laws of the jurisdiction where it resides, so cloud regions matter and legal jurisdiction follows the data. Regulations such as GDPR and CCPA apply by the location of the data subject.

Slide 37 · Exam alignment

Quick alignment with the paper. Objective 12.1: governance, covering the document types, roles and accountability, external obligations and compliance. Objective 12.2: risk management, covering identification and assessment, the register and appetite, the four responses, vendors, reporting and business impact.

Objective 12.3: data protection, covering classification, roles, lifecycle, privacy law and sovereignty. And assurance and awareness: attestation, penetration testing, awareness design and phishing. This completes the five-domain map for the course.

Slide 38 · Key takeaways

Here are the takeaways. Governance sets direction, through policy, standard, guideline and procedure. Authority decides, and accountability answers. Risk is identified, assessed, recorded in a register and given an owner. Single loss expectancy and annualised loss expectancy put money on a risk, and appetite and tolerance define how much risk the business will live with. The four responses are avoid, transfer, mitigate and accept. Vendors extend your risk, so assess, contract and monitor them. Compliance is a baseline, audits prove it, and a good awareness programme turns users into sensors.

Slide 39 · Quiz

[Direct candidates to [Quiz_Session_12.html](#). 15 minutes.] Open the final session quiz. Twenty questions, immediate feedback, and every question is tagged with the exam objective it tests, so you will see the tag, like 12.2 Risk Management, above each question. Read every explanation. Aim for seventy percent or better.

Slide 40 · Your next step is the exam

That brings the course to a close, and thank you for staying with it to the end. Across twelve sessions you have covered five domains, from network models and cryptography through to architecture, operations, and the programme management of this session. Revise those domains, revisit the quizzes, and practise the performance based questions. Then book the exam and sit it while the material is fresh. The pass mark is seven hundred and fifty, and you have the knowledge to reach it. Go and earn it, and stay curious.

Slide 41 · You are exam-ready

[Close the course warmly.] Twelve sessions, five domains, complete. General Security Concepts in sessions one and two. Threats, Vulnerabilities and Mitigations in three to five. Security Architecture in six and seven. Security Operations in eight to eleven. And Security Program Management today. Good luck in the exam, and stay curious. The certification is the start, not the destination.